EVANGELISCHE/ANGELISCHE LANDESKIRCHE IN BADEN
NDESKIRCHE BADEN

Notfallplan

INHALTSVERZEICHNIS

1 DOKUMENTENINFORMATION....1
1.1 Dokumentendaten....2
1.2 Dokumentenhistorie....2
1.3 Beteiligte Personen....2
1.4 Mitgeltende Dokumente....2
1.5 Rechtliche Grundlage....2
2 ZWECK, ANWENDUNGSBEREICH UND ANWENDER....2
3 REFERENZDOKUMENTE....3
4 ALLGEMEINER NOTFALLPROZESS....3
4.1 Störung/(IT-)Notfall....3
4.2 Zielsetzung und Anforderungen....4
4.3 Sofortmaßnahmen....4
4.4 Informationssicherheitsmanagementsystem (ISMS)....6
5 ALARMIERUNGSPLAN TEAM....7
5.1 Notfallrufnummern....8
5.2 Meldung....8
5.3 Lagebeurteilung....9
5.3.1 Reichweite des Notfalls....10
5.3.2 Auswirkung auf die Prozesse....10
5.3.3 Mögliche Ausbreitung....10
5.3.4 Situation außerhalb der Organization....10
5.3.5 Notbetrieb....10
5.3.6 Deeskalation....10
6 ORGANISATORISCHE VORGABEN....10
6.1 Einführung des IT-Notfallteams (braucht es das? Krisenstab reicht()....10
6.2 Kompetenzen....11
6.2.1 Geschäftsleitung....11

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

6.2.2 IT-Notfallteam....11
6.3 Raum....11
7 ORGANISATORISCHE ABWICKLUNG....12
7.1 Dokumentation (IT-Notfallprotokoll) bei einem Notfall....14
7.2 Interne und externe Kommunikation....15
8 WIEDERANLAUFPLÄNE FÜR SPEZIFISCHE NOTFÄLLE....16
8.1 Stromausfall (intern und flächendenkend)....18
8.2 Internetausfall....18
8.3 Brandfolgen....18
8.4 Naturkatastrophen....19
8.5 Epidemie / Pandemie....19
8.6 M365 Entra ID....19
8.7 M365 E-Mail....20
8.8 M365 Sharepoint....20
8.9 M365 Teams....21
8.10 Website ekiba.de....21
8.11 Cyber-Angriffe und Schadsoftware....21
9 CYBER-ANGRIFFE UND SCHADSOFTWARE ALS SONDERFALL....22
9.1 Kurzbeschreibung....22
9.2 Beurteilung der Angriffsstufe....22
9.3 Häufige Angriffsszenarien....23
9.3.1 Ransomware (Verschlüsselungstrojaner)....23
9.3.2 Phishing / Kompromittierte E-Mails:....23
9.3.3 Ungewöhnliche Systemaktivität....23
9.4 Maßnahmen nach Angriffsstufe....23
9.4.1 Stufe 1 - Lokale EOK-Infrastruktur....23
9.4.2 Stufe 2 - Rechenzentrum TelemaxX....23
9.4.3 Stufe 3 - Microsoft Cloud (M365/Azure)....24
9.4.4 Stufe 4 - Beide kritische Säulen....24
9.5 Wiederherstellung nach Priorität....24
9.5.1 Priorität 5 - Absolut kritisch:....24

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

9.5.2 Priorität 4 - Sehr wichtig:.....24
9.5.3 Priorität 3 - Wichtig:.....25
9.5.4 Meldungen und Kommunikation:.....25
10 NACHBEREITUNG EINES NOTFALLS.....25
11 LISTE BERECHTIGTER PERSONEN.....26

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

1 Dokumenteninformation

1.1 Dokumentendaten

Typ	Dokumenten Verantwortlicher	Version 1
Leitlinie	Informationssicherheitsbeauftragter (ISB)	Siehe Info im SharePoint

1.2 Dokumentenhistorie

Letzte Änderung	Bearbeiter	Status	Freigabe am	Freigabe durch

1.3 Beteiligte Personen

Name	E-Mail-Adresse	Telefonnummer	Rolle
Rolf, Ulrich	Ulrich.rolf@eh-freiburg.de	150	Kanzler
Spillmann, Sophia	Sophia.spillmann@eh-freiburg.de	630	Assistentin des Kanzlers
Trautmann, Peter	Peter.trautmann@eh-freiburg.de	210	Haustechnik
Eitenbichler-Hölzle, Johannes	Johannes.eitenbichler@eh-freiburg.de	470 0162-4614919	Leitung IT
Bauer, Jochen	jochen.bauer@secudor.de	0172-2776557	Secudor

1.4 Mitgeltende Dokumente

- Schutzbedarfsfeststellung (https://ekiba.sharepoint.de/sites/AbteilungIT-ISO27000/Freigegebene%20Dokumente/ISMS%20EH-Freiburg/02_Verzeichnisse/Schutzbedarfsfeststellung-Arbeitskopie.xlsx?web=1)
- Schutzbedarf-IT-Anwendungen (https://ekiba.sharepoint.de/sites/AbteilungIT-ISO27000/Freigegebene%20Dokumente/ISMS%20EH-Freiburg/02_Verzeichnisse/Schutzbedarf-IT-Anwendungen-Arbeitsversion.xlsx?web=1)
- Dienstleisterliste (https://ekiba.sharepoint.de/sites/AbteilungIT-ISO27000/Freigegebene%20Dokumente/ISMS%20EH-Freiburg/02_Verzeichnisse/Lieferantenliste_2025.xlsx?web=1)
- Wiederanlaufplan (muss noch erstellt werden)

1.5 Rechtliche Grundlage

Die enthaltenen Informationen dieses Notfallhandbuches, sind angelehnt an den BSI Standard 100-4 / 200-4 sowie die ISO27001 (A.5.29 – A.5.32).

2 Zweck, Anwendungsbereich und Anwender

Das Notfallhandbuch ist Teil des EOK-Informationssicherheitsmanagementsystems (ISMS) und regelt zu ergreifende Abläufe, Maßnahmen und Zuständigkeiten bei Notfällen an der Evangelischen Hochschule Freiburg.

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

Ziel dieses Dokumentes ist es, einfach und übersichtlich alle Informationen bereitzustellen, um im Notfall eine schnelle und sichere Wiederaufnahme des unterbrochenen Betriebs sicherzustellen. So soll sichergestellt werden, dass auch in erhöhten Stresssituationen keine wichtigen Schritte vergessen werden und trotz schneller Ergreifung von geeigneten Maßnahmen, eine Dokumentation gepflegt wird, welche auch eine spätere Auswertung des Vorfalls ermöglicht.

Dieses Dokument liegt immer sowohl in elektronischer Form auf dem SharePoint des EOK unter dem Aktenzeichen 1480-00-10 > 03 als auch in Papierform vor. Das Handbuch in Papierform wird dabei sicher in einem XXX des XXX aufbewahrt. Dieses XXX ist für alle berechtigten Personen zugänglich. Weiterhin liegt eine elektronische Variante auf verschlüsselten XXX der Mitarbeitenden der IT-XXX bereit.

Da das Notfallhandbuch ein vertrauliches Dokument ist, sind die Anwender*innen dieses Dokumentes alle berechtigten Personen mit Zugriff auf dieses Dokument. Eine Liste der berechtigen Personen befindet sich dabei unter Punkt 11.

3 Referenzdokumente

Das Formular für das Notfallprotokoll befindet sich im Kanal „ISO27000“ unter „ISMS EOK/07_Dokumentationen/Vorlagen“.

4 Allgemeiner Notfallprozess

4.1 Störung/(IT-)Notfall

Die Unterscheidung zwischen Störung, Notfall, Krise und Katastrophe wird nicht immer eindeutig verstanden. Aus diesem Grund soll hier ein klares Verständnis für die Organisation abgebildet werden.

Ein IT-Notfall liegt vor, wenn essenzielle Prozesse oder Ressourcen ausfallen und die jeweils produktspezifische maximale Wiederherstellungszeit (RTO) überschritten wird. Die Ausfalldauer richtet sich dabei nach der jeweils kürzesten für das betroffenen Produkt definierten RTO – unabhängig von den allgemeinen Geschäftszeiten. Essenzielle Ressourcen sind hierbei:

- *lokale ADs (eh-freiburg, eh-lehre)*
- *Open LDAP*
- *RemoteDesktop-Server (RDS1, RDS2, Ncomputing4)*
- *Telefonserver (3cx)*
- *Backups*
- *ILIAS*

Der aktuelle Stand der kritischen Dienste ist in der Datei „Schutzbedarfsfeststellung“ zu finden. Der aktuelle Stand der kritischen IT-Anwendungen ist in der Datei „Schutzbedarf-IT-Anwendungen“ zu finden.

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

Erst dann, wenn Störungen oder Ausfälle größere Schäden verursachen können und ihre Behebung mit den üblichen Verfahren nicht mehr möglich ist, erfordern sie ein Notfallmanagement.

4.2 Zielsetzung und Anforderungen

Primäres Ziel ist die Ausbreitung des Schadens zu verhindern und den schnellst-möglichen Wiederanlauf sicherzustellen.

Sekundäres Ziel ist die vollständige Wiederherstellung des Zustands entsprechend der RPO aus der Liste „Schutzbedarfsfeststellung“.

Des Weiteren sind Gebäudepläne mit eingezeichneten Notausgängen, sowie den Standorten der Feuerlöscher und Erste-Hilfe-Kästen vorhanden.

Außerdem gibt es einen Erste Hilfe Aushang mit zu befolgenden Schritten am Haupteingang.

4.3 Sofortmaßnahmen

Als erste Schritte bei der Notfallbewältigung ist die Sicherheit und Unversehrtheit von Personen zu gewährleisten.

Sind Personen akut gefährdet, gilt der Grundsatz: Umgebung sichern, Ereignis melden, Personen versorgen.

Nach Meldung eines notfallrelevanten Ereignisses stellt das IT-Notfallteam den Informationsfluss zu allen an der Durchführung der Sofortmaßnahmen beteiligten Personen sicher.

Hierzu gibt es auch verschiedene Aushänge mit allen wichtigen Informationen:

An der Tür des Erste Hilfe-Raums (Anbau C, Raum 003) hängt eine Übersicht mit Notfallrufnummern und den benannten Ersthelfer, Sicherheitsbeauftragter, Fachkraft für Arbeitssicherheit und der Betriebsarzt. Zudem sind die Informationen in der Infothek+ im Bereich „Sicherheit und Notfälle“ hinterlegt.

A) **Organisation**

- Bewahren **Sie Ruhe und handeln Sie nicht übereilt**.

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

- Richten Sie einen **Krisenstab** ein.
- Klären Sie **regelmäßig folgende Fragen**:
  - Wer macht was bis wann?
    - Welche Tagesaufgaben können für die Bewältigung des Vorfalls liegen gelassen werden?
  - Wer trifft die relevanten Entscheidungen?
  - Sollen Systeme schnell wieder aufgesetzt werden oder Spuren gesichert werden?
  - Wer kommuniziert was wann an wen?
  - Wollen Sie Anzeige erstatten?
- Denken Sie an **Meldepflichten**.
- Holen Sie sich bei Bedarf frühzeitig **externe Unterstützung**.
- Kurzfristig für den Notbetrieb wichtige Daten können sich auch an ggf. abgesetzten Außenstellen oder auf Systemen von Mitarbeitern im Urlaub befinden, welche (noch) nicht betroffen sind.
- Mit einem **Abfluss von Daten** ist zu rechnen.

B) **Technik**

- Oberste Regel: **Keinesfalls darf eine Anmeldung mit privilegierten Nutzerkonten (Administratorkonten) auf einem potenziell infizierten System erfolgen**, während das System sich noch im internen produktiven Netzwerk befindet oder mit dem Internet verbunden ist!
- **Potenziell infizierte Systeme sollten umgehend vom Netzwerk isoliert werden**, um eine weitere Ausbreitung der Schadsoftware im Netz durch Seitwärtsbewegungen (Lateral Movement) zu verhindern. Dazu das Netzwerkkabel ziehen. Gerät nicht herunterfahren oder ausschalten. Gegebenenfalls forensische Sicherung inkl. Speicherabbild für spätere Analysen (eigene, durch Dienstleister oder Strafverfolgungsbehörden) erstellen.
- Die Schadprogramme nehmen teilweise tiefgreifende (sicherheitsrelevante) Änderungen am infizierten lokalen System vor, die nicht einfach rückgängig gemacht werden können. Das BSI empfiehlt daher grundsätzlich, **infizierte lokale Systeme als vollständig kompromittiert zu betrachten und neu aufzusetzen**.
- Fortschrittliche Schadsoftware-Varianten können sich mit **ausgespähten Zugangsdaten für Benutzerkonten** (ggf. mit administrativen Rechten) lateral im Netzwerk ausbreiten. Beachten Sie die Problematik eines „Golden Tickets“ und Kompromittierungen von Domaincontrollern und Serversystemen (Active Directory und alle domain-joined Systeme neu aufsetzen). Sollte das nicht schnell möglich sein, muss das Passwort des eingebauten Key Distribution Service Accounts (KRBTGT) zweimal zurückgesetzt werden. Dies invalidiert alle Golden Tickets welche mit dem zuvor gestohlenen KRBTGT-Hash und allen anderen Kerberos Tickets erzeugt wurden.[1]
- **Alle auf betroffenen Systemen gespeicherten bzw. nach der Infektion eingegebenen Zugangsdaten sollten als kompromittiert betrachtet und die Passwörter geändert werden.** Dies umfasst u. a. Webbrowser, E-Mail-Clients, RDP/VNC-Verbindungen sowie andere Anwendungen wie PuTTY, FileZilla, WinSCP, etc.

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

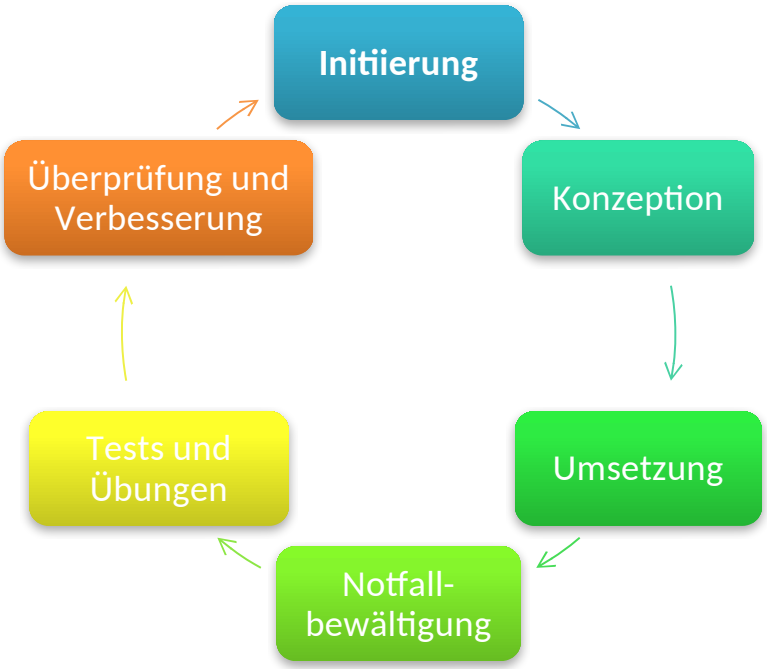
- **Blockieren Sie jede nicht unbedingt benötigte Remote-Verbindung, beobachten Sie den Netzwerkverkehr und lassen Sie Antiviren-Scans laufen um weitere Infektionen und Täterzugriffe auszuschließen.**
- Prüfen Sie, **ob Sie saubere, nicht kompromittierte Backups haben**.
- Im Fall einer bereits erfolgten Verschlüsselung sollten Sie grundsätzlich **nicht auf die Erpressung eingehen und kein Lösegeld bezahlen.** Stattdessen sollten die Daten in ein sauberes Netzwerk aus Backups zurückgespielt werden.
- Eine **Persistenz von Schadsoftware** im BIOS oder gar der Hardware ist sehr selten und wird bislang nicht von breit verteilter Schadsoftware angewandt.
- Um einen zukünftigen weiteren Zugriff der Täter auf das interne Netzwerk und eine erneute Ausbreitung von Schadsoftware auszuschließen, **sollte im Fall einer Kompromittierung des AD das Netz unbedingt komplett neu aufgebaut werden**. Dies kann nach einer schnellen Bereinigung u.U. auch langfristig nach Sicherstellung der Betriebsfähigkeit erfolgen.

4.4 Informationssicherheitsmanagementsystem (ISMS)

Das Notfallmanagement ist in das ISMS der Evangelischer Oberkirchenrat Karlsruhe integriert und ein wesentlicher Bestandteil. Aus diesem Grund ist auch für Notfälle ein kontinuierlicher Verbesserungsprozess nach dem PDCA-Modell (Plan-Do-Check-Act) etabliert.

- Analyse der bestehenden Prozesse, Definition des Bedarfs und Planung der Umsetzung
- Umsetzung der geplanten Maßnahmen
- Test und Überprüfung der Wirksamkeit
- Optimierung und Mängelbeseitigung

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx



/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

5 Alarmierungsplan team

5.1 Notfallrufnummern

Nachfolgend aufgelistet sind Rufnummern, um bei einem Notfall wichtig sind, um Dritte, wie Einsatzkräfte, aber auch Telekommunikationsanbieter oder Stromanbieter erreichen zu können.

Funktion:	Kontakt:	Daten:	E-Mail:	Rufnummer:
Rektorin	Prof. Dr. Renate Kirchhoff		renate.kirchhoff@eh-freiburg.ekiba.de	100
Dr. Ulrich Rolf (Vorsitz), Kanzler			Ulrich.rolf@eh-freiburg.de	150
Johannes Eitenbichler (Ltg. IT)			Johannes.eitenbichler@eh-freiburg.de	470 0162-4614919
Sophia Spillmann (Personal/Organisation)			Sophia.spillmann@eh-freiburg.de	630
Barbara Hirth (Hochschulkommunikation)			Barbara.hirt@eh-freiburg.de	790
Ziar Kabir (Datenschutzbeauftragter)				
Engler? Frank? Trautmann?				
Erweiterter Krisenstab: Thomas Koch, EOK-Rechtsabteilung Vorsitz MAV				

5.2 Meldung

Denken Sie an etwaige Meldepflichten etwa nach DSGVO, BSIG und anderen Gesetzen gegenüber Regulatoren. Beachten Sie außerdem etwaige Verpflichtungen aus vertraglichen Vereinbarungen.

Bei DSGVO-Verstößen wie dem Abfluss personenbezogener Daten – was etwa bei Emotet-Infektionen durch das Ausspähen von E-Mails aus Outlook-Postfächern immer der Fall ist – ist außerdem die in Art. 33 DSGVO genannte **Meldeverpflichtung gegenüber der zuständigen Aufsichtsbehörde (EKD-Aufsichtsbehörde) zwingend zu beachten. Eine Meldung hat i.d.R. innerhalb von 72 Stunden zu erfolgen**. Daneben - was häufig übersehen wird - sind in besonders risikoträchtigen Fällen auch die konkret betroffenen natürlichen Personen - also diejenigen Personen, deren Daten abgeflossen sind (Mitarbeiter, Kunden, Newsletterempfänger, ...) - in nachvollziehbarer, verständlicher Art über die betroffenen Dateninhalte, das Missbrauchspotenzial sowie die eigenen ergriffenen Schutzmaßnahmen zu informieren (Art. 34 DSGVO)[1]. Selbst wenn ein Angriff relativ früh entdeckt wird, ist die Wahrscheinlichkeit groß, dass bereits die Daten, an denen der Angreifer ein Interesse und auf die er Zugriff hat, abgeflossen sind. So leitet die Schadsoftware „Emotet“ automatisiert Kontaktbeziehungen und E-Mail-Inhalte von Outlook aus.
Auch aus den von Ihnen geschlossenen Verträgen können Pflichten zur Information Ihrer Vertragspartner bestehen.

Alle sicherheitskritischen Meldungen gehen grundsätzlich in das Ticketsystem [illegible], welche speziell gekennzeichnet werden (Priorität). Situativ werden parallel die Vorgesetzten oder verantwortlichen Personen persönlich, telefonisch, per Teams oder E-Mail kontaktiert.

In besonders zeitkritischen Notsituationen z.B. mit (drohendem) Personenschaden o.ä. werden Notdienste sofort vom Anwesenden verständigt. Diese werden im Nachgang entsprechend dem Notfallprotokoll im Ticketsystem dokumentiert. Das Ticket wird entsprechend dem Betreff „***Notfall:*** *XX*“ erstellt und mit der „***Priorität 5 – sehr hoch***“ zu versehen.

Nachdem Sofortmaßnahmen eingeleitet wurden, wird der Leitende Direktor / Stv. Direktor wie folgt informiert. Kontaktmethoden in absteigender Prioritätsreihenfolge:

i. Persönlich
ii. Telefon / Dienstsmartphone
iii. Teams und E-Mail

5.3 Lagebeurteilung

Die Schadensbewältigung setzt eine genaue Schadensanalyse voraus. Zusätzlich zu den bei der Kategorisierung unter Kapitel 3.4 gewonnenen Erkenntnissen ist eine Übersicht über die vorhandenen Daten (nicht betroffene Systeme, Backups), sowie über die von externen Datenquellen zu erlangenden Daten zu erstellen.

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

Neben einer Bemessung des Schadens ist die Aufklärung der Schadensursache erforderlich. So kann sichergestellt werden, dass die für den Sicherheitsvorfall verantwortlichen Schwachstellen beseitigt werden können.

Das IT-Notfallteam führt eine Lagebeurteilung durch. Bei der Beurteilung der Situation sind immer folgende Kriterien ausschlaggebend:

5.3.1 Reichweite des Notfalls

- Was ist betroffen
- Wie viel ist betroffen
- Geographische Abgrenzung

5.3.2 Auswirkung auf die Prozesse

- Welcher Prozess, welches System oder welche Infrastruktur ist primär gestört
- Welcher Prozess, welches System oder welche Infrastruktur ist durch Folgereaktion gestört

5.3.3 Mögliche Ausbreitung

- Ist eine Ausbreitung auf weitere Prozesse, Systeme oder Infrastruktur möglich

5.3.4 Situation außerhalb der Organization

- Ist der Notfall anderen Unternehmen oder Behörden bekannt
- Sind ähnliche Notfälle zeitgleich in den gängigen Medien bekannt

5.3.5 Notbetrieb

Als Ergebnis dieser Lagebeurteilung ist ein Notbetrieb zu definieren und entsprechende Maßnahmen einzuleiten, um diesen Notbetrieb zu erreichen.

5.3.6 Deeskalation

Kriterien für die Beendigung des Notfalls werden ebenfalls hier definiert.

6 Organisatorische Vorgaben

6.1 Einführung des IT-Notfallteams (braucht es das? Krisenstab reicht?)

Für die Bewältigung größerer Notfälle und um auf unvorhergesehene Ereignisse reagieren zu können, wird ein IT-Notfallteam eingerichtet. Dieses besteht immer aus den folgenden Personen:

- Abteilungsleitung IT
- Kanzler
- ISB
- Öffentlichkeitsarbeit ?

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

- Leitwerk (Kriseninterventionsteam Hochschule BaWü)

Darüber hinaus werden jeweils betroffene Produktverantwortliche und der DSB hinzugezogen.

6.2 Kompetenzen

6.2.1 Geschäftsleitung

Den taktischen Teil der Notfallbewältigung trifft die Geschäftsleitung, bzw. bei IT-Problemen die Abteilungsleitung IT zusammen mit den Organisationsmitarbeitern. Dies ist ein planendes, koordinierendes, informierendes, beratendes, entscheidungstreffendes und unterstützendes Organ.

6.2.2 IT-Notfallteam

Es stellt eine besondere temporäre Aufbauorganisation dar, die eine normale Aufbauorganisation zur Bewältigung eines Notfalls durchbricht und fachbereichsübergreifende Kompetenzen bündelt. Es plant, koordiniert, veranlasst und überwacht die Aktivitäten der Notfallbewältigung und steuert die Bereitstellung aller relevanten Informationen und Ressourcen zur Bewältigung des Schadensereignisses.

Die folgenden Aufgaben sollten im IT-Notfallteam wahrgenommen werden:

- Die Situation muss erfasst und bewertet werden. Alle wichtigen Informationen müssen regelmäßig aktualisiert werden.
- Aufträge zur Notfallbehebung müssen an die zuständigen Instanzen erteilt und die hierfür erforderlichen Aktivitäten koordiniert werden.
- Die Abstimmung der einzelnen Maßnahmen muss geregelt werden.
- Zuständig für den Wiederanlauf bzw. die Wiederherstellung von Geschäftsprozessen, Anwendungen oder Systemen.
- Das IT-Notfallteam kann zur Bewältigung ggf. Experten hinzuziehen.
- Das IT-Notfallteam ist für die Dokumentation aller Entscheidungen und Vorgänge verantwortlich.

Das IT-Notfallteam ist während der Notfallbewältigung gegenüber des Leitenden Direktors / des Stv. Direktors in regelmäßigen Abständen berichtspflichtig.

6.3 Raum

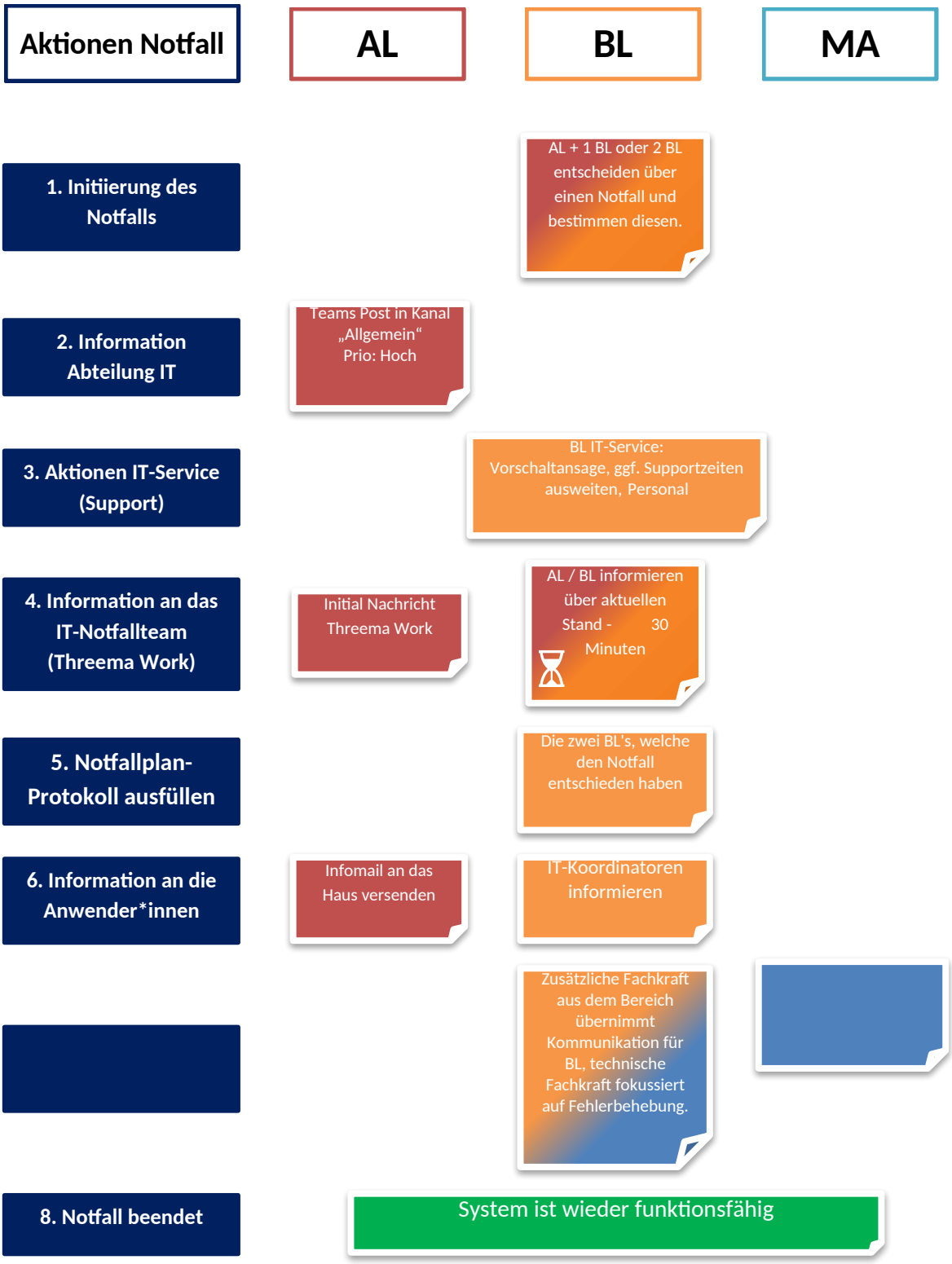
Für die Treffen des IT-Notfallteams werden feste Orte zur Zusammenkunft definiert. Grundsätzlich kommuniziert das IT-Notfallteam per Threema-Work. Bei Bedarf kann der Konferenzraum („Raum der Begegnung“) genutzt werden. Dieser kann ebenfalls für eine hybride Konferenz genutzt werden, falls Teile des IT-Notfallteams sich im Homeoffice befinden. Sollte dies nicht möglich sein, da der Raum zum Zeitpunkt des Treffens nicht nutzbar ist, wird auf eine virtuelle Konferenz ausgewichen. Sollte ein physisches Treffen nicht möglich sein, oder sollten äußere Umstände wie zum Beispiel ein Epidemie-/Pandemiegeschehen ein physisches Treffen verhindern wird

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

eine Teams Konferenz einberufen werden. So können ebenfalls Personen, welche nicht physisch teilnehmen können, hinzugeschaltet werden.

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

7 Organisatorische Abwicklung



/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

Nachbereitung Notfall	AL	BL	MA
9. Information Notfallteam	Information in Threema-Work über Abschluss		
10. Aktionen Support		Aktionen von Schritt 3 prüfen: z.B: Ansagen deaktivieren	
11. Information Geschäftsleitung	E-Mail an LDir und 7Oh senden		
12. Information Anwender*innen	Infomail an das Haus über Abschluss	Ein Post im Kanal der IT-Koordinatoren, dass das Problem gelöst wurde.	
13. Fertigstellung Notfall-Protokoll	Abnahme vom Notfall-Protokoll	Die **zwei BL's**, welche den Notfall entschieden haben. Speicherort: ISMS EOK/07_Dokumentationen/Notfallprotokolle	
14. Versendung Notfall-Protokoll	Notfall-Protokoll als PDF speichern und in der Threema-Work Notfallgruppe teilen		

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

7.1 Dokumentation (IT-Notfallprotokoll) bei einem Notfall

Damit das Schutzniveau des Unternehmens verbessert werden kann, ist eine Analyse und daraus erforderliche, verbesserte Maßnahmen notwendig. Aus dem IT-Notfallteam muss ein IT-Notfallprotokoll mit Ursache, Auswirkung und Schutzmaßnahmen hervorgehen. Sollte die Notwendigkeit einer Prozessänderung aus dieser Analyse hervorgehen, sind entsprechende Maßnahmen anzustoßen. Um die zielgerichtete Dokumentation zu gewährleisten und den Dokumentationsprozess so einfach wie möglich zu halten, sind Checklisten und Formulare als eine Vorlage im Notfallprotokoll vereint. Speicherort Notfallprotokoll siehe *Punkt 3 Referenzdokumente*. Das ausgefüllte Protokoll ist danach im Ticketsystem zu hinterlegen.

7.2 Interne und externe Kommunikation

Bereitstellung der notwendigen Kommunikationsinfrastruktur

- Je nach Ausmaß des Sicherheitsvorfalls kann es sein, dass die vorhandene Kommunikationsinfrastruktur (PC mit Internet, (VoIP-)Telefonie) nicht mehr einsatzfähig ist. Stellen Sie daher rechtzeitig eine **geeignete Ersatzinfrastruktur** (Laptops mit mobilem Hotspot, Handys mit Headsets) für die mit der Kommunikation befassten Stellen bereit.
- **Stakeholder identifizieren und Sprachregelung abstimmen**
- Für eine geeignete Krisenkommunikation muss klar sein, wer der Empfänger der Informationen sein soll / muss.
  z.B. Mitarbeitende, Studierende, Lehrbeauftragte, Ev. Landeskirche in Baden, MWK, die allgemeine Öffentlichkeit
- **Interne Kommunikation vor externer Kommunikation**
- Zuerst Information der Mitarbeitenden und zeitnahes unterrichten über die Hintergründe des Vorfalls, um Spekulationen zu vermeiden.
- **Senden von „we care“-Botschaften, nichts zu sagen ist keine empfehlenswerte Option**
- Prüfen einer Medieninformation zur Erlangung der Informationshoheit und zur Vermeidung von Spekulationen. Es ist möglich, dass die interne Information der Mitarbeiter nach außen gelangt. In diesem Fall muss die Hochschule sprechfähig sein.
- **Bündelung des Informationsflusses und Nutzung von FAQs**
- Die Kanäle, über die Sie Krisenkommunikation betreiben, sollten sorgsam gewählt werden. Beachten Sie bei der Auswahl die bekannten Informationskanäle (zentrale E-Mail-Adressen, Rufnummern, etc.) und planen sie den Informationsfluss so, dass
- **Sagen Sie öffentlich sowie gegenüber ihren Mitarbeitenden jederzeit die Wahrheit!**
- Formulieren Sie gemeinsam mit Ihrem Pressesprecher eine Sprachregelung zum Vorfall und informieren Sie frühzeitig Ihre Mitarbeiter.

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

Interne Kommunikation: *jegliche Kommunikation, die der Bewältigung des Notfalls dient (z.B. Meldung, Informationsbeschaffung oder Absprache mit Rettungsdiensten)*

Vorgaben: Für die interne Kommunikation der Organisation während eines Notfalls werden die folgenden Kommunikationsmittel je nach Verfügbarkeit und Effektivität genutzt:

Persönliche Kommunikation, Teams, Threema Work „EKIBA-Notfallgruppe“, (Mobil-)Telefon oder per E-Mail (sofern verfügbar).

Dabei gilt, dass mindestens einmal alle 2 volle Stunden im IT-Notfallteam kommuniziert werden muss. Ein Bericht zur externen Kommunikation muss einmal täglich erstellt und im IT-Notfallteam besprochen werden. Darüberhinausgehende Sitzungen und Lageberichte bzw. andere Zeitintervalle werden in den Dokumentationsformularen festgehalten.

Grundsätzlich gilt für die Weitergabe von Informationen weiterhin die Richtlinie zur Klassifizierung von Informationen. Abweichungen davon darf der Notfallteams für den Zeitraum des Notfalls festlegen. Dies ist schriftlich festzuhalten.

Sollte eine Kommunikation mit Datenschutz-Behörden erforderlich sein, übernimmt dies grundsätzlich der DSB.

Externe Kommunikation: *jegliche Kommunikation, die nach außen hin informiert und nicht mit der Bewältigung des Notfalls in Zusammenhang steht*

Vorgaben: Bei Notfällen obliegt die externe Kommunikation dem/der Pressesprecher*in. Informationsstände werden nur durch diese an externe Medien weitergegeben. Sollte abweichend davon die externe Kommunikation durch andere Positionen durchgeführt werden, wird dies im Einzelfall explizit durch die Geschäftsleitung benannt und beauftragt. Dies ist ebenso in der Dokumentation festzuhalten.

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

8 Wiederanlaufpläne für spezifische Notfälle

Nachfolgend befinden sich spezifische Informationen und Handlungsanweisung für die Wiederherstellung und den Wiederanlauf von einzelnen Ressourcen. Des Weiteren werden auch systemübergreifende Ausfälle berücksichtigt. Die Pläne sind dabei absteigend nach der Kritikalität der Ressource(n) aufgelistet.

Die Wiederherstellung der vollständigen Arbeitsfähigkeit erfordert regelmäßig das Neuaufsetzten des betroffenen Active Directories. Zur kurzfristigen Wiederherstellung einer Teilarbeitsfähigkeit bietet es sich an, jede Dienstleistung zunächst einer der folgenden vier Kategorien zuzuordnen.

„Nicht betroffen“

Dienstleistungen, die keines der betroffenen Systeme verwenden.

„Auslagerungsfähig“

Dienstleistungen, die betroffene Systeme verwenden, die aber auf ein anderes eigenes oder fremdes System ausgelagert werden können. Die Auslagerungsfähigkeit kann je nach Dienstleistungen aber insbesondere auch nach der Größe der Organisation, der Organisationsumwelt und der eigenen ADLandschaft stark variieren. In diese Kategorie gehören Dienstleistungen, bei denen kurzfristig ein anderer Standort der Organisation oder eine andere Organisation innerhalb eines Organisationsverbunds (z.B. anderes Konzernunternehmen, benachbarte Kommune, Geschäftsstelle eines Verbands) die erforderliche IT-Ausstattung (neben Clients auch Server mit entsprechenden Fachverfahren) für die eigenen Beschäftigten zur Verfügung stellen kann.

„mit mobilem Equipment zumindest eingeschränkt Arbeitsfähig“

Dienstleistungen, die betroffene Systeme verwenden, aber auch mit mobilem, nicht betroffenen, Equipment („sauberer“ Laptop, mobiler Hotspot, Handy) zumindest eingeschränkt erbracht werden können. In Abgrenzung zu auslagerungsfähigen Dienstleistungen handelt es sich hier um die Bereiche, bei denen die eingesetzten Softwaresysteme entweder rein Clientseitig funktionieren oder die externe Serverkomponente über das Internet erreichbar ist.

„ohne Neuaufbau nicht Arbeitsfähig“

Dienstleistungen, bei denen die Arbeitsfähigkeit nicht nach den vorgenannten Kategorien besteht oder hergestellt werden kann.

In einem nächsten Schritt können dann unter den Dienstleistungen jeder Kategorie diejenigen identifiziert werden, die als funktionswichtig angesehen werden und deshalb priorisiert lauffähig gemacht werden müssen.

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

8.1 Stromausfall (intern und flächendenkend)

Maßnahme:	Beschreibung
Kurzbeschreibung:	Ein Stromausfall kann drei Eskalationsstufen annehmen: 1. Teil-Ausfall Gebäude (z. B. ausgelöster LS-Schalter) 2.Stadt-/Landkreis-weiter Ausfall 3.Landes- oder Bundesweiter Blackout Die Lagebeurteilung erfolgt binnen ≤ 10 Min. durch das IT-Notfallteam (Monitoring, Stadtwerke-Ticker, Satellitenradio). Wesentliche Parameter: Ausmaß, voraussichtliche Dauer, Verfügbarkeit Kommunikationsnetze, USV-Restlaufzeit. Ab Stufe 2 übernimmt das Notfallteam
Mögliche Maßnahmen	
Kritische Applikationen:	
Ansprechpartner intern:	
Ansprechpartner extern:	
Relevante Dokumente:	

8.2 Internetausfa

Kurzbeschreibung:	Ein Ausfall der Internet- bzw. WAN-Verbindung kann drei Eskalationsstufen annehmen: 1. Leitungsschaden vor Ort (z. B. Bagger beschädigt Glasfaser) 2.Standort-weiter Totalausfall (alle Leitungen / Medien gestört) 3.Regionale oder überregionale Störung (Landkreis, Bundesland, national) Die Lagebeurteilung erfolgt binnen ≤ 10 Min. durch das IT-Notfallteam (Provider-Statusseiten, WAN-Monitoring, Auskunft Telekommunikationsaufsicht). Ab Stufe 2 wird das IT-Notfallteam informiert
Maßnahmen	
Kritische Ressourcen:	
Ansprechpartner intern:	
Ansprechpartner extern:	
Relevante Dokumente:	

8.3 Brandfolgen

Kurzbeschreibung:	
Maßnahmen	
Kritische Ressourcen:	

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

Ansprechpartner intern:	
Ansprechpartner extern:	
Relevante Dokumente:	
Wiederanlaufplan:	

8.4 Naturkatastrophen

Kurzbeschreibung:	Eine Naturkatastrophe liegt vor, wenn ein unvorhergesehenes Naturereignis wie z.B. Unwetter (Hagel, Wirbelstürme, Schneestürme usw.), Waldbrände, Erdbeben und damit verbundene Auswirkungen am Standort TelemaxX auftritt.
Maßnahmen	
Kritische Applikation:	
Ansprechpartner intern:	
Ansprechpartner extern:	
Relevante Dokumente:	

8.5 Epidemie / Pandemie

Kurzbeschreibung:	Eine Epidemie / Pandemie liegt vor, wenn eine Infektionskrankheit mit hohen Erkrankungszahlen und schweren Krankheitsverläufen vorliegt.
Maßnahmen	
Kritische Applikationen:	
Ansprechpartner intern:	
Ansprechpartner extern:	
Relevante Dokumente:	

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

8.6 M365 Entra ID

Kurzbeschreibung:	Ein Ausfall des Entra ID Cloud-Dienstes liegt vor, wenn die Entra ID Dienste nicht korrekt funktionieren oder nicht zur Verfügung stehen. Anmeldungen, die im Zusammenhang mit Azure AD stehen funktionieren ggf. nicht mehr. Somit sind auch andere Microsoft Dienste betroffen. Microsoft 365 Mail (Anmeldung erforderlich) Microsoft 365 Teams (Anmeldung erforderlich) Microsoft 365 Share Point und OneDrive (Anmeldung erforderlich)
Maßnahmen	
Kritische Applikationen	
Ansprechpartner intern:	
Ansprechpartner extern:	
Relevante Dokumente:	

8.7 M365 E-Mail

Kurzbeschreibung:	Ein Ausfall von M365 E-Mail liegt vor, wenn keine E-Mails mehr zugestellt oder versendet werden können. Die Kommunikation ist dann stark eingeschränkt.
Maßnahmen	
Kritische Applikation:	
Ansprechpartner intern:	
Ansprechpartner extern:	
Relevante Dokumente:	

8.8 M365 Sharepoint

Kurzbeschreibung:	Ein Ausfall von M365 Sharepoint liegt vor, wenn die aktive Datenablage und davon abhängige Dienste eingeschränkt sind und nicht mehr genutzt werden können. Mit dem Ausfall von Sharepoint steht mit hoher Wahrscheinlichkeit auch OneDrive nicht zur Verfügung, in Teams ist mit Einschränkungen der Funktionalität zu rechnen, bis hin zum Totalausfall des Dienstes

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

Maßnahmen	
Kritische Applikation:	
Ansprechpartner intern:	
Ansprechpartner extern:	
Relevante Dokumente:	

8.9 M365 Teams

Kurzbeschreibung:	Ein Ausfall von M365 Teams liegt vor, wenn die Anwendung Teams oder abhängige Dienste gestört oder eingeschränkt sind
Maßnahmen	
Kritische Applikation:	
Ansprechpartner intern:	
Ansprechpartner extern:	
Relevante Dokumente:	

8.10 Website ekiba.de

Kurzbeschreibung:	Die Website stellt ein wichtiges Tool der Außenkommunikation für das Unternehmen dar. Unangekündigte Ausfälle oder Verbreitung von Schadsoftware sowie Fälschen von Texten über diese kann einen erheblichen Schaden für das Unternehmen in Form einer Rufschädigung oder Schadensersatzklagen sowie Bußgelder erzeugen. Ein Notfall der Website liegt vor, wenn die Website nicht verfügbar ist, ungewollte Weiterleitungen durchführt oder Schadsoftware verteilt.
Maßnahmen	
Kritische Applikationen:	
Ansprechpartner intern:	
Ansprechpartner extern:	
Relevante Dokumente:	

8.11 Cyber-Angriffe und Schadsoftware

Kurzbeschreibung:	Bei einem Cyber-Angriff ist die Reichweite der betroffenen Systeme entscheidend für den Wiederanlauf eines Notbetriebs. Falls der „Angriff“ sich nur auf die lokale IT-Infrastruktur (EOK)

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

	beschränkt, kann ein Notbetrieb der kritischen Applikationen problemlos durch "mobiles Arbeiten" erfüllt werden. Wenn jedoch ein Angriff oder „Infizierung“ auf Landkreis- oder sogar Landesebene ausgemacht werden kann, sind ganz andere Maßnahmen anzuwenden und verantwortliche Stellen betraut. Bei einem Cyberangriff sind häufig die Schutzziele gefährdet oder gebrochen. Was sind Indizien für einen möglichen Angriff? • Plötzliche Spitzen bei CPU-/Netzlast, ungewöhnlicher Traffic • Massives Fehlschlagen von Anmeldeversuchen / Kontosperrungen • Auftreten unbekannter Benutzer, Geräte oder Schatten-Domänen • Alarmmeldungen IDS/IPS, AV • Verschlüsselungs- bzw. Löschversuche auf Server/Clients • Unerklärlicher Ausfall kritischer Dienste oder Weiterleitungen
Maßnahmen	
Kritische Applikationen:	
Ansprechpartner intern:	
Ansprechpartner extern:	

9 Cyber-Angriffe und Schadsoftware als Sonderfall

9.1 Kurzbeschreibung

Bei einem Cyber-Angriff ist die **Reichweite** der betroffenen Systeme entscheidend für den Wiederanlauf eines Notbetriebs. Die EKIBA hat zwei kritische IT-Säulen: das **externe Rechenzentrum TelemaxX** (mit allen kritischen Fachverfahren) und **Microsoft Cloud-Services** (M365/Azure für Kommunikation). Diese beiden Säulen können sich **nicht gegenseitig ersetzen** - jeder Ausfall führt zu schweren Einschränkungen mit unterschiedlichen Auswirkungen.

9.2 Beurteilung der Angriffsstufe

Stufe 1: Lokale EH-Infrastruktur

- Betroffene Systeme: Arbeitsplätze, lokale Switches, WLAN im Gebäude, Drucker
- Auswirkung: Begrenzt - kritische Systeme laufen extern weiter
- Maßnahme: Homeoffice/mobiles Arbeiten, alternative Standorte

Stufe 2: Rechenzentrum TelemaxX

- Betroffene Systeme: Phoenix, KFM, Buchungsplan, Fundus, OTOBO, Citrix, Domaincontroller, Azure
- Auswirkung: Kritische Fachverfahren nicht verfügbar
- Maßnahme: Notfallprozesse aktivieren, TelemaxX kontaktieren, VPN-Tunnel in Azure auf Backup Internetleitung schalten (Azure wieder anbindbar)

Stufe 3: Microsoft M365/Azure (Cloud)

- Betroffene Systeme: E-Mail, Teams, SharePoint, Entra ID, Intune

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

- Auswirkung: Kommunikation und Cloud-Arbeitsplätze eingeschränkt
- Maßnahme: Notfallprozesse aktivieren, Microsoft kontaktieren (Punkt 5.1, MIRP), TelemaxX-Systeme weiter nutzen, Alternative Kommunikationswege nutzen (NFON-Telefonie, Threema Work)

Stufe 4: Beide kritische Säulen betroffen

- Betroffene Systeme: TelemaxX UND Microsoft
- Auswirkung: Kritische Störung fast aller Geschäftsprozesse
- Maßnahme: Wiederanlaufplan, externe Unterstützung, Papier-Prozesse

9.3 Häufige Angriffsszenarien

9.3.1 Ransomware (Verschlüsselungstrojaner)

Erkennungsmerkmale:

- Dateien können nicht mehr geöffnet werden
- Lösegeldforderungen auf dem Bildschirm
- Ungewöhnliche Dateiendungen (.locked, .encrypted)

Sofortmaßnahmen:

9.3.2 Phishing / Kompromittierte E-Mails:

Erkennungsmerkmale:

- Verdächtige E-Mails mit Links oder Anhängen
- E-Mails werden ohne Wissen versendet
- Passwort funktioniert plötzlich nicht mehr

Sofortmaßnahmen:

9.3.3 Ungewöhnliche Systemaktivität

Erkennungsmerkmale:

- Computer sehr langsam oder verhält sich seltsam
- Unbekannte Programme laufen
- Hohe Netzwerkaktivität ohne erkennbaren Grund
- Zugriffe außerhalb der normalen Arbeitszeiten

Sofortmaßnahmen:

9.4 Maßnahmen nach Angriffsstufe

9.4.1 Stufe 1 - Lokale EOK-Infrastruktur

Sofortmaßnahmen:

Notbetrieb:

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

- Alle kritischen Systeme funktionieren weiter (TelemaxX + M365)
- Arbeiten vollständig mobil möglich
- Nur physische Anwesenheit im EOK-Gebäude eingeschränkt

9.4.2 Stufe 2 - Rechenzentrum TelemaxX

Sofortmaßnahmen:

Nicht mehr verfügbare Systeme:

- Alle Systeme welche On-Prem im Rechenzentrum gehostet werden (siehe Schutzbedarfsfeststellung)

Eingeschränkter Notbetrieb:

- E-Mail und Teams (M365) - Kommunikation funktioniert
- SharePoint - Dokumentenablage verfügbar
- Office-Anwendungen - Grundlegende Büroarbeit möglich

9.4.3 Stufe 3 - Microsoft Cloud (M365/Azure)

Sofortmaßnahmen:

Nicht mehr verfügbare Systeme:

- E-Mail (Outlook) → Telefon, persönliche Kontakte
- Teams → Telefonie über NFON/Mobilfunk
- SharePoint → Lokale Dateiserver (falls vorhanden)
- Office 365 → Lokale Office-Versionen (falls installiert) -> potenziell LibreOffice zur Verfügung stellen
- Entra ID → Nur lokales AD verfügbar

Eingeschränkter Notbetrieb:

- Alle Fachverfahren (OTOBO, KFM, Phoenix, DaviP, DKB)
- Citrix-Arbeitsplätze (wenn TelemaxX funktioniert)
- Lokales Active Directory

9.4.4 Stufe 4 - Beide kritische Säulen

Sofortmaßnahmen:

9.5 Wiederherstellung nach Priorität

9.5.1 Priorität 5 - Absolut kritisch:

- **TelemaxX-Verbindung** (über TelemaxX)
- **M365 Basisdienste** (E-Mail, Teams)

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

- **OTOBO** (Ticketsystem für Koordination)
- **KFM** (Finanzverwaltung)

9.5.2 Priorität 4 - Sehr wichtig:

- Phoenix (Finanzwesen)
- DaviP (Kirchenverwaltung)
- SharePoint (Dokumentenmanagement)
- Citrix-Infrastruktur

9.5.3 Priorität 3 - Wichtig:

- DKB (Digitales Kirchenbuch)
- Weitere Fachanwendungen
- Lokale EOK-Infrastruktur

9.5.4 Meldungen und Kommunikation:

Interne Meldung:

- **Sofort:** Abteilung IT informieren (OTOBO-Ticket erstellen)
- **≤ 30 Min:** Abteilungsleitung IT
- **≤ 1 Stunde:** Leitender Direktor / Stv. Direktor
- **≤ 2 Stunden:** ISB/DSB (bei Datenschutzverletzung)

Externe Meldung (bei schweren Vorfällen):

- **Leitwerk**
- **≤ 72 Stunden:** Aufsichtsbehörde Datenschutz (bei Datenschutzverletzung)
- **Bei Erpressung:** Polizei kontaktieren

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

10 Nachbereitung eines Notfalls

Denken Sie an eine Nachbesprechung zur Auswertung und Verbesserung.

- Welche langfristigen Maßnahmen müssen ergriffen werden?
- Was ist gut gelaufen, wo gibt es Verbesserungspotenzial?
- An welchen Stellen sollten Sicherheitsmaßnahmen verbessert werden?

Planen Sie eine **Revision Ihrer IT durch Externe**, sobald die Maßnahmen umgesetzt sind. Die Liste zertifizierter IT-Sicherheitsdienstleister in den Geltungsbereichen IS-Revision und IS-Penetrationstests benennt IT-Sicherheitsunternehmen, die ihre Leistungsfähigkeit in diesen Bereichen bewiesen haben[4]. Darüber hinaus können diese ggf. weitere fallrelevante Angebote machen.

Danken Sie Ihren Vertragspartnern und Kunden für das Verständnis, die Geduld und die Unterstützung. Planen Sie mit etwas Abstand ein "Dankeschön" für Ihre an der Vorfallbewältigung beteiligten Mitarbeiter. Nutzen Sie Ihre Möglichkeiten von Prämien, Sonderurlaub, **Abschluss-Party** ☺, etc. Auch diese "kleine Investition" rentiert sich langfristig!

Nach jedem bewältigten Notfall (bzw. nach jeder Notfallübung) erfolgt eine Nachbereitung des Notfalls. Dies umfasst sowohl den Notfallhergang/Auslöser und Präventivmaßnahmen als auch die Effektivität der Notfallbewältigung und der vorhandenen Notfallpläne. Hierzu gilt es zum einen zu klären, wie der Notfall entstanden ist, ob dies mit anderen Präventivmaßnahmen hätte verhindert werden können, ob eine Präventivmaßnahme nicht wie vorgesehen funktioniert hat oder ausgefallen ist und wie und nach welcher Zeit der Notfall erkannt wurde. Zum anderen gilt es den Ablauf der Notfallbewältigung zu analysieren. Hier muss geklärt werden, wie gut die vorhanden Notfallmaßnahmen und Pläne funktionieren oder ob diese ausgebaut oder verändert werden müssen. Hierzu zählen nicht nur die Notfallpläne, sondern auch organisatorische Maßnahmen wie die Einberufung des IT-Notfallteams, die Effektivität der Kommunikation (intern wie extern) und die getroffenen Entscheidungen und beschlossen Maßnahmen zur Notfallbewältigung. Hierzu sind in jedem Fall die während des Notfalls ausgefüllten Dokumentationsformulare zu berücksichtigen und auszuwerten. Letztendlich sollen aus den Analysen, Maßnahmen zur Verbesserung des Notfallhandbuchs bzw. des Notfallbewältigungsprozess abgeleitet werden und ein abschließender Bericht mit den Analysepunkten und den abgeleiteten Maßnahmen zur Verbesserung erstellt werden. Dieser wird mindestens im Kreis des IT-Notfallteams (und der gesamten Geschäftsleitung) besprochen.

Der Bericht ist nachfolgend im ISMS EOK/07_Dokumentationen/Notfallprotokolle abzulegen.

11 Liste berechtigter Personen

- IT-Notfallteam
- Abteilung IT

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx

- Leitender Direktor
- ISB/DSB

/home/joba/joba/ws-latex/infosec-tooling/artefakte/notfallhandbuch/ehf/Notfallplan_EH.docx